

CISM Domain 1A — Enterprise Governance: Exam Essentials

Domain 1 (Information Security Governance) = 17% of the exam ≈ 26 of 150 questions.

Your exam (July 2026) uses the 2022 content outline — the new outline only takes effect Nov 3, 2026.

The #1 Exam Mindset

“It’s all about the business.”

The most important objective of information security governance: **ensure the security strategy aligns with the business’s strategic goals and objectives.** When a question asks for the BEST/FIRST/MOST important answer, the option tied to business alignment usually wins. Governance must be **top-down** — executive-level insight and support is critical.

Governance vs. Strategy vs. Management

Concept	Role	Sets
Governance	Direction and oversight; balances stakeholder needs	The “why” and “what” — vision, risk appetite, policies
Strategy	Desired state of security + roadmap to get there	The “how” at a high level — priorities, initiatives
Management	Implements governance direction via the strategy roadmap	Executes the “how” — controls, day-to-day ops

Enterprise governance = the overall framework directing ALL organizational activities.

Information security governance = a specialized subset of enterprise governance that embeds security into business processes.

Planning Horizons

- **Strategic (3–5 yrs):** CEO → org strategy; CIO → IT strategy; CISO → InfoSec strategy
- **Tactical (1 yr):** Security Manager → tactical planning
- **Operational (1–3 mo):** Admins/technicians → operational planning and execution

Accountability vs. Responsibility (guaranteed exam trap)

- **Accountability:** answers for the outcome. **ONE person. CANNOT be delegated.**
- **Responsibility:** does the work. **May be multiple people. CAN be delegated** (delegator stays accountable).
- **Span of control:** number of direct reports a manager can supervise (<10 ideal).

Six Outcomes of Information Security Governance

1. **Strategic alignment** — investments support business objectives
2. **Risk management** — risk kept within the org’s risk tolerance
3. **Value delivery** — cost-effective, standardized, proportionate to risk
4. **Resource optimization** — efficient use; knowledge captured; processes formalized
5. **Performance measurement** — metrics tied to objectives (“can’t manage what you can’t measure”)

6. **Assurance process integration** — all assurance functions coordinated; no gaps/overlaps

Assurance processes = activities confirming controls work as intended (risk assessments, audits, vuln scans, pen tests, compliance reviews).

Charter vs. Scope

- **Charter** = authority + objectives (who has power to act, why the program exists)
- **Scope** = coverage + boundaries (where, to whom, to what extent it applies)

Three Circles of Security

Information security (broadest — all information, any format) $\supset$ **IT security** (info within IT systems) $\supset$ **Cybersecurity** (protecting connected systems from cyberattack).

Organizational Culture (1A1)

- Security is about **people and behavior**, not just technology.
- **Security manager's role**: build relationships, influence behavior, tailor communication (“what’s in it for me?”). **Culture change takes time** — exam tip.
- Positive-culture indicators: security involved in projects early; employees know how to report incidents; everyone knows their role.
- **AUP**: defines permitted/prohibited activities for anyone handling org assets (employees, contractors, third parties); users sign to acknowledge.
- **Ethics**: modeled by leadership; aligned with mission/vision/values. Know the **ISACA Code of Professional Ethics** — support standards compliance, due diligence, lawful/honest stakeholder service, confidentiality (unless law requires disclosure), work only within your competence, disclose all significant results, support stakeholder education.

Legal, Regulatory & Contractual Requirements (1A2)

Three compliance types: **Legal** (laws, broad jurisdiction — e.g., CCPA), **Regulatory** (agency-enforced — HIPAA, SOX, GDPR, FERPA), **Contractual** (vendor agreements — e.g., PCI DSS, ISO 27001 clauses).

- **Legal and regulatory requirements take precedence** — regulatory compliance is a standalone driver needing **no further justification** (classic exam question).
- **Due diligence** = reasonable proactive steps to identify/assess/address risk (audits, IR plan testing, awareness training).
- Applicable requirements determined by: industry, geography, data processed (PII/PHI), and customer contracts. Consult legal counsel; run gap analyses; monitor regulatory change.
- **Record retention**: driven by jurisdiction rules on how long to keep and when to destroy; records in legal proceedings are under **legal hold** (cannot be destroyed).

Roles & Responsibilities (1A3) — know who does what

Role	Key exam points
Board of Directors	Highest governing body; ultimate responsibility; sets RISK APPETITE; selects CEO; fiduciary duty
Senior Management	Implements board intentions; provides budget/resources; ensures alignment

CEO	Top executive; reports to board; responsible for all aspects of success
CISO	Owns InfoSec program & strategy; develops, implements, and ENFORCES security policy
CPO	Privacy program, PII oversight; coordinates with CISO
CRO	Enterprise-wide risk management (often includes infosec risk)
Risk / Control Owners	Risk owner = accountable for a risk; control owner = maintains the control
Business Process Owners	Management-level, may be non-technical; best understand operational needs; make key business decisions
Steering Committee	Senior members of affected groups; communication channel between security and business; ensures stakeholders are considered

Best way to align security with business functions → establish an information security governance/steering committee (classic exam answer).

RACI Matrix

- **Responsible** — does the work (can be several)
- **Accountable** — owns the outcome (**exactly one**)
- **Consulted** — provides input/expertise (two-way)
- **Informed** — receives updates only (one-way)

Living document; review regularly; match assignments to skills.

Quick Self-Check (from the handout)

1. BEST way to align security with business functions? → **Governance/steering committee**
2. Driver needing no further justification? → **Regulatory compliance**
3. Who enforces security policies? → **CISO**

Last-Minute Memory Hooks

- Alignment with business > everything else
- Accountability: one person, never delegated
- Regulatory compliance: no justification needed
- Board sets risk appetite; CISO enforces policy; steering committee bridges security and business
- Governance = top-down, always